Normativa de Seguridad de la Información

Sistema de Gestión de Seguridad de la Información

480

SOLUCIONES CUATROOCHENTA, S.A.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

Índice

Índice **2**

1. OBJETIVO DE LA NORMATIVA DE SEGURIDAD **3**

2. ENTORNO DE GESTIÓN DE LA SEGURIDAD **4**

2.1 ALCANCE *4*

2.1.1 Empleados 4

2.1.2 Activos 5

2.2 ROLES Y RESPONSABILIDADES *5*

3. CLASIFICACIÓN DE LA INFORMACIÓN **6**

3.1 Clasificación de la información conforme a su sensibilidad *6*

3.2 Reglas para manejo y custodia de la información *7*

3.3 Resumen implementación de las etiquetas en MS365 *9*

4. POLÍTICA DE MESAS LIMPIAS **9**

5. POLÍTICAS DE USO DE RECURSOS **10**

5.1 5.1.- DE DISPOSITIVOS *12*

5.2 DEL CONTROL DE ACCESOS *13*

5.2.1 Acceso físico 13

5.2.2 Acceso lógico 14

5.2.3 Credenciales y contraseñas 15

5.3 DEL CORREO Y OTRAS PLATAFORMAS. *15*

5.4 DE HERRAMIENTAS DE INTELIGENCIA ARTIFICIAL (IA) *16*

5.5 DE CONECTIVIDAD *17*

5.5.1 Red corporativa 17

5.5.2 Acceso remoto y teletrabajo 18

5.6 DE PROTECCIÓN DE LA PROPIEDAD INTELECTUAL *19*

5.7 DE CONTROLES CRIPTOGRÁFICOS *19*

5.8 DE FIRMA ELECTRÓNICA *20*

5.9 DE SUPERVISIÓN Y EVALUACIÓN *20*

6. SANCIONES **21**

7. MANTENIMIENTO Y REVISIÓN DE NORMATIVA **22**

8. DISTRIBUCIÓN DE LA NORMATIVA **22**

9. APROBACIÓN **22**

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

1. OBJETIVO DE LA NORMATIVA DE SEGURIDAD

El buen funcionamiento de la organización depende en gran medida de los Sistemas de Información y la Información que almacenan. La Normativa de Seguridad tiene como misión desarrollar los objetivos de Seguridad establecidos en la Política de Seguridad para la organización, así como proteger los activos de información.

Estos objetivos incluyen la adopción de una serie de medidas organizativas y normas que se presentan en este documento con la finalidad de proteger la información del Grupo Cuatroochenta (en adelante, Cuatroochenta), detallando, además, los compromisos que adquieren sus usuarios respecto a la seguridad y buen uso con independencia de la entidad desde la que presten sus servicios, ya sea esta la empresa matriz Soluciones Cuatroochenta S.A. como sus subsidiarias, cuyos datos constan en la *Política de Seguridad (SGSI01)*.

Asimismo, se detallan las precauciones y medidas de seguridad adoptadas para asegurar el correcto cumplimiento de la legislación vigente aplicable al ámbito de actividad de Cuatroochenta, como la normativa europea del *Reglamento General de Protección de Datos* (RGPD), complementada por la normativa estatal española, con la entrada en vigor el 7 de diciembre de 2018 de la nueva *Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales* (LOPDGDD).

Dado que alguna de las entidades filiales de Cuatroochenta tienen su sede fuera del territorio de la UE, pero parte de los tratamientos de datos se realizan también desde la sede la matriz ubicada en España, se deberá aplicar, además de la normativa especificada la propia del territorio donde se efectúan parte de los tratamientos de datos. Dicha normativa se identifica en la *Política de Seguridad (SGSI01)*.

El objetivo principal de la creación de esta Normativa de Seguridad por parte de Cuatroochenta es **garantizar a los usuarios el acceso a la información con la cantidad y calidad que se requiere para el desempeño del trabajo, así como evitar pérdidas de información y accesos no autorizados a la misma**.

Deben respetarse los siguientes principios:

1. *Confidencialidad*: La información perteneciente a Cuatroochenta o a sus clientes, debe ser conocida exclusivamente por las personas autorizadas, previa identificación, en el momento y por los medios habilitados.

2. *Integridad*: La información de Cuatroochenta, debe de ser completa, exacta y válida, siendo su contenido el facilitado por los afectados sin ningún tipo de manipulación.

3. *Autenticidad*: La información de Cuatroochenta, es generada por un autor identificado que es imposible de suplantar, lo que incluye el no repudio de la información introducida pues se garantiza que el emisor de la información es quien dice ser.

4. *Disponibilidad*: La información de la organización está accesible y utilizable por los usuarios autorizados e identificados en todo momento, quedando garantizada su propia persistencia ante cualquier eventualidad prevista.

5. *Trazabilidad*: Se implementarán los mecanismos necesarios para garantizar que cualquier acción realizada sobre los recursos de información de Cuatroochenta pueda ser rastreada a posteriori.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

Esta Normativa de Seguridad será mantenida, actualizada y adecuada a los fines de Cuatroochenta, alineándose con el contexto, la gestión y la estrategia de la organización, evaluando los riesgos inherentes a la misma y su actividad.

Cuatroochenta quiere transmitir a todos sus empleados, la obligación existente respecto a la confidencialidad de la información y la normativa en materia de protección de datos. Todos deben ser conscientes del tratamiento que llevan a cabo en el desempeño de sus labores cotidianas e, independientemente del soporte en el que se encuentre la información, deben aplicar el máximo celo en la utilización y custodia de ésta.

Como se desprende del *Acuerdo de Confidencialidad y No Divulgación de Información*, los empleados están obligados a guardar confidencialidad de manera indefinida, incluso más allá de la relación laboral o profesional con Cuatroochenta.

Las medidas establecidas en la presente normativa de seguridad serán extensibles para cualquier cesión de información que se realice a terceras entidades. Solo se permite dicha cesión cuando esté justificada, se tomen las medidas oportunas y esté regulada por un acuerdo entre ambas partes para el intercambio de dicha información y, en el mismo, se defina la finalidad exacta de dicha cesión, así como la caducidad de esta y la garantía de supresión de la misma una vez cumplido el objetivo de la cesión.

Finalmente, se establece el uso aceptable de los recursos de la compañía mediante una serie de normas definidas para proteger tanto a los empleados de Cuatroochenta como a sus recursos e información. Un uso inapropiado de estos recursos expone a la compañía a riesgos relevantes, incluyendo ataques de *malware*, sistemas y/o servicios de red comprometidos, fugas de información, así como cuestiones de cumplimiento normativo o jurídicas.

2. ENTORNO DE GESTIÓN DE LA SEGURIDAD

La organización dispone de un *Sistema de Gestión de Seguridad de la Información* (SGSI) definido para dar cumplimiento al estándar ISO/IEC 27001[1], así como al *Esquema Nacional de Seguridad*[2] (ENS). Por ello, esta normativa de seguridad se encuentra alineada con estas especificaciones.

Todas las políticas y procedimientos incluidos en este documento y en el SGSI han sido revisados, aprobados e impulsados por el Comité de Seguridad Interna y por la Dirección de Cuatroochenta.

2.1 ALCANCE

2.1.1 Empleados

La Seguridad de la Información es un **esfuerzo conjunto**. Requiere la implicación y participación de todos los miembros de la organización. Por ello, todo empleado de Cuatroochenta debe conocer y cumplir los requerimientos de la Política y Normativa de Seguridad de la Información y su documentación asociada. Los empleados que deliberadamente o por negligencia incumplan alguna de las políticas de seguridad estarán sujetos a acciones disciplinarias según se contempla en el presente documento.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

2.1.2 Activos

Las políticas afectan a todos los activos de información de la organización: equipos informáticos (PC´s, portátiles, servidores), smartphones, infraestructuras de redes y comunicaciones, software y todos los recursos a los que tenga acceso el personal o usuario para el cumplimiento de tareas asignadas en el ámbito laboral, incluyendo documentación en otros formatos como pueda ser el papel.

2.2 ROLES Y RESPONSABILIDADES

La seguridad de Cuatroochenta es responsabilidad de todos sus empleados y, por lo tanto, es obligación de cada uno de ellos conocer y aplicar las medidas que se establecen en este documento.

Es obligación de todo el personal de la compañía comunicar inmediatamente (por correo, chat o teléfono) al Responsable de Seguridad de la Información (CISO) cualquier incidencia que detecte en los recursos a los que tenga acceso durante el desempeño de su actividad. Entendiendo como incidencia cualquier anomalía que afecte o pueda afectar a la seguridad de la información. El contacto está disponible en el apartado de contactos de emergencia en la intranet.

El Comité de Seguridad Interna, liderado por el CISO, es el responsable de establecer, documentar y distribuir la Política y Normativa de Seguridad de la Información, estándares, directivas y procedimientos de seguridad de la Organización. Así como de implementar los medios y canales necesarios para que se puedan detectar, gestionar y solucionar las incidencias y anomalías que puedan ocurrir en los sistemas.

El CISO tiene a cargo la investigación, el seguimiento, documentación y análisis de los incidentes de seguridad reportados, así como su comunicación a los implicados en el incidente, al Comité de Seguridad Interna y/o al Comité de Crisis según sea su impacto. La documentación de las incidencias, así como su seguimiento, quedará debidamente registrado.

El Responsable del Área de Recursos Humanos incluirá las funciones relativas a la seguridad de la información en las descripciones de puestos de los empleados, informará a todo el personal que ingresa de sus obligaciones respecto del cumplimiento de la Política y Normativa de Seguridad de la Información, gestionará los Acuerdos de Confidencialidad con el personal y coordinará las tareas de formación y concienciación de los usuarios respecto de la presente normativa.

Los responsables de las distintas áreas deberán revisar y velar por el cumplimiento de las políticas de seguridad establecidas por Cuatroochenta del personal de su área, de que se respete la confidencialidad de información dentro de su grupo y de asegurarse que se emiten las notificaciones correspondientes en caso de incidentes.

Todos y cada uno de los usuarios son responsables de la protección y adecuado tratamiento de los datos y recursos a los cuales se tiene acceso, por tanto, se deberá velar por el cumplimiento de todas las medidas que se especifican en el presente documento.

Las acciones disciplinarias en respuesta a los incumplimientos de la Política y Normativa de Seguridad son atribución de la Comisión Ejecutiva de Cuatroochenta, siempre en base a la legislación aplicable.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

3. CLASIFICACIÓN DE LA INFORMACIÓN

3.1 Clasificación de la información conforme a su sensibilidad

La información de Cuatroochenta está clasificada en 4 categorías dependiendo de su grado de confidencialidad. Esta clasificación está basada en el protocolo TLP[3], proporcionando un esquema sencillo e intuitivo para indicar con quién se puede compartir información potencialmente confidencial. TLP es ampliamente reconocido, por lo que se facilita la comunicación entre entidades y organizaciones a nivel nacional e internacional. Todo empleado debe ser consciente de esta clasificación:

1. *PÚBLICO* (**TLP:CLEAR**): Usamos esta categoría cuando la información conlleve un riesgo mínimo o nulo de uso indebido. Esta información puede ser compartida sin restricciones. Como ejemplos: información comercial o cualquier publicación dirigida al sitio web de Cuatroochenta.

2. *GENERAL* (**TLP:GREEN**): Para información con divulgación limitada. Asignamos esta categoría cuando la información sea útil una comunidad más amplia. Los destinatarios podrán compartir esta información con sus iguales y con organizaciones asociadas dentro de su comunidad, pero no a través de canales de acceso público. Como ejemplos: Newsletter o comunicaciones generales a inversores.

3. *RESTRINGIDO* (**TLP:AMBER**)*:* Esta información sólo podrá difundirse en base al principio de mínimos privilegios dentro de Cuatroochenta (contratados y subcontratados que hayan firmado acuerdo de confidencialidad) y con terceros reconocidos (clientes, proveedores, etc.) con algún tipo de contrato, oferta, descripción de proyecto, etc. Dentro de esta categoría se podrá restringir la difusión sólo a miembros de Cuatroochenta mediante la subcategoría *Restringido Interno (***TLP:AMBER+STRICT***)*. Se incluyen en esta categoría:

    - Políticas de Seguridad
    - Propuestas comerciales y contratos con clientes o proveedores
    - Documentación de proyectos y productos
    - Documentación de cumplimiento
    - Documentación de configuración y sistemas
    - Registros de incidencias, problemas, cambios, etc.
    - Información administrativa y contable
    - Información operativa (Zoho)
    - Todo lo que no sea amplia difusión y no esté catalogado como Confidencial.

1. *CONFIDENCIAL* (**TLP:RED**): Esta información debe ser únicamente compartida para los ojos y oídos de los destinatarios individuales, sin que sea posible más divulgación. Asignamos esta categoría cuando la información no pueda ser utilizada eficazmente sin un riesgo significativo para la privacidad, la reputación o las operaciones de las organizaciones implicadas. Información confidencial es:

    - Datos de carácter personal dentro del ámbito de aplicación de la RGPD

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

- Credenciales de acceso
- Resultados de auditorías de seguridad de clientes e internas
- Código fuente de las aplicaciones de Cuatroochenta y de clientes
- Registros de trazabilidad de los usuarios en las diferentes plataformas
- Copias de seguridad
- Información financiera y de M&A
- Notificaciones del Canal Ético y documentación asociada a los casos
- Otra información sensible

3.2 Reglas para manejo y custodia de la información

Cada uno de los empleados es responsable de tomar las medidas oportunas para prevenir la salida de información no autorizada. En particular, el autor del recurso de información lo clasificará en base a las categorías descritas en el apartado anterior, lo etiquetará aprovechando las capacidades técnicas que permita la plataforma destino de este y asegurará su correcta custodia.

Cualquier pérdida de información sensible o uso no autorizado debe ser comunicada inmediatamente al responsable y al CISO para poder tomar las medidas oportunas lo antes posible.

*PÚBLICO (**TLP:CLEAR**)*

En este caso la información puede difundirse libremente, pudiendo incluir su aparición en Internet.

Como medida preventiva, antes de proceder a su publicación, eliminaremos cualquier información sensible que pueda aparecer en los metadatos de todos los recursos[4].

*GENERAL (**TLP:GREEN**)*

La única restricción para la información de esta categoría es que no puede ser accesible de forma abierta en internet.

Como en el caso anterior, eliminaremos cualquier información sensible que pueda aparecer en los metadatos de todos los recursos.

*RESTRINGIDO (**TLP:AMBER**)*

La información puede ser compartida entre los empleados de Cuatroochenta en función de sus necesidades de acceso para poder llevar a cabo su labor.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

La información de carácter Restringido se almacena siempre y únicamente en los servidores o plataformas autorizadas por Cuatroochenta, y es accesible exclusivamente a través de los clientes de las propias plataformas, con el debido control de accesos.

Cuando un empleado genere, reciba o clasifique información restringida, debe almacenarla aplicando el esquema de autorización adecuado según el principio de mínimos privilegios, permitiendo el acceso únicamente a los usuarios que lo requieran.

En caso de que la información restringida deba ser accesible sin conexión a los sistemas de la organización, se permitirá una copia de esta en la máquina local, dentro de una carpeta con acceso exclusivo al usuario que deba utilizarla, y procediendo al borrado de la información una vez deje de ser necesaria.

La mayoría de esta documentación es de uso interno y no debe ser propagada a través de ningún medio ni salir de la organización a través de ningún soporte.

Aquella información categorizada como *Restringido Interno* (**TLP:AMBER+STRICT**) no podrá compartirse con terceros externos a Cuatroochenta.

La información de uso restringido que se intercambia con determinados clientes o proveedores (ofertas, contratos…) debe realizarse a través de medios seguros y fiables y con una clara referencia a la distribución exclusiva del documento entre las personas autorizadas.

En la medida de lo posible se evitará la difusión de este tipo de información a través de correo electrónico u otros medios. Para ello, se referirá a la misma en su ubicación original (Sharepoint, BitBucket, Zoho Projects…), controlando en todo momento el nivel de acceso.

Finalmente, si necesitamos acceder a información de carácter restringido en espacios públicos, deberemos instalar físicamente en nuestros equipos filtros diseñados para limitar la visibilidad de la pantalla hacia sus laterales, impidiendo que otra persona pueda ver lo que en ella aparece.

CONFIDENCIAL (**TLP:RED**)

La información confidencial debe almacenarse con medidas de control de acceso, restringiendo al máximo el mismo sólo al personal autorizado que realmente lo requiera, siguiendo el principio de mínimos privilegios. Puntualizando y ampliando las medidas anteriores.

Cualquier recurso clasificado como Confidencial, debe ser etiquetado como tal aprovechando las capacidades técnicas que permita la plataforma destino de este. Adicionalmente, en cualquier documento escrito debe figurar la referencia “CONFIDENCIAL” en la portada y a lo largo del documento.

Físicamente, tanto si la información es archivada en formato papel como en otros soportes, deberá custodiarse bajo llave.

Se prohíbe expresamente copiar, mover y almacenar información confidencial en unidades de disco locales y dispositivos electrónicos extraíbles, a menos que sea autorizado explícitamente para una necesidad de negocio definida mediante una petición dirigida al Comité de Seguridad Interna a través de correo o gestor de tareas. En ese caso: la información debe viajar cifrada, se tomarán las medidas

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

oportunas para evitar su robo y no se dejarán los medios desatendidos en ningún momento y se usarán únicamente en equipos con software de seguridad actualizado de los que se conozca perfectamente el origen y sean confiables.

En información especialmente sensible como estudios de M&A, desde el origen, se definirá un seudónimo para referir al tercero internamente, de forma que no quede referencia directa al mismo en las diferentes plataformas de trabajo.

Una vez ya no son necesarios, en la mayor brevedad posible, debe procederse a la destrucción de cualquier documento confidencial de manera segura, bien en las destructoras de papel disponibles o, análogamente, cualquier soporte extraíble con información confidencial deberá ser destruido o formateado de manera segura según los procedimientos establecidos.

3.3 Resumen implementación de las etiquetas en MS365

De forma acorde a las categorías establecidas y las reglas de manejo y custodia de la información en las mismas, se ha creado un conjunto de etiquetas de confidencialidad en el entorno de MS365 que nos permitirán gestionar de forma adecuada todos los elementos en este contexto. El siguiente cuadro resume estas etiquetas:

Etiqueta	Descripción	Configuración
PÚBLICO (**TLP:CLEAR**)	Esta información puede ser compartida con cualquier persona en el mundo a través de canales públicamente accesibles; no hay límite en la divulgación.	No cifrado Invitados permitidos Enlaces directos habilitados
GENERAL (**TLP:GREEN**)	Esta información puede compartirse dentro de nuestra comunidad, incluyendo clientes y socios, pero no a través de canales públicamente accesibles.	No cifrado Invitados permitidos
RESTRINGIDO (**TLP:AMBER**)	Utilizar para información sensible destinada a personas específicas dentro o fuera de la organización.	Cifrado Invitados permitidos
RESTRINGIDO (**TLP:AMBER+STRICT**)	La divulgación de esta información está limitada y sólo podemos compartir con personas dentro de la organización.	Cifrado Invitados **no** permitidos
CONFIDENCIAL (**TLP:RED**)	Para los ojos y los oídos de los destinatarios individuales únicamente, no se permite ninguna divulgación adicional. Los destinatarios no pueden imprimir o copiar la información.	Cifrado Permiso sólo lectura No aplicable a grupos

4. POLÍTICA DE MESAS LIMPIAS

El objetivo de la política de “mesas limpias” es regular y controlar la custodia de la información soportada en papel, en dispositivos electrónicos u otros soportes. De esta manera, prevenimos que la información esté al alcance de terceros no autorizados. Todos los usuarios que tengan asignado un puesto dentro del centro de trabajo de Cuatroochenta o aquéllos otros que no teniéndolo asignado, acceden a dicho centro para trabajar con su equipo, deberán cumplir la normativa especificada en este apartado:

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

2. Una vez terminada la jornada laboral y en ausencia del usuario, todo soporte físico que ha sido utilizado ha de ser guardado en un lugar seguro y no visible, no debiendo quedar encima de las mesas de trabajo ningún elemento susceptible de contener cualquier tipo de información.

3. Toda información que se imprime, copia o escanea debe ser recogida de la máquina conforme se vaya imprimiendo, de esta manera se evitará que pueda estar al alcance de terceros no autorizados.

4. El usuario mantendrá los dispositivos de visualización de datos (pantallas, monitores, etc.) que sean dependientes de su puesto de trabajo, orientados de tal forma que se imposibilite su visualización por el personal no autorizado.

5. Siempre que abandonen el puesto de trabajo, deberán apagar el dispositivo o activar previamente el bloqueo de pantalla, de tal forma que para desbloquearlo se precise la introducción de sus credenciales.

6. Al salir de salas de reuniones debemos asegurarnos de que no quedan documentos visibles ni información sensible en pizarras o pantallas.

7. En las videollamadas, si debemos compartir contenidos, nos aseguraremos de que sólo mostramos aquello necesario y que no aparece información sensible que sea filtrada a personal no autorizado. Para ello, debemos primar el compartir ventanas de aplicaciones concretas en lugar de pantalla completa y que éstas estén preparadas para la ocasión sólo con la información necesaria.

5. POLÍTICAS DE USO DE RECURSOS

Cualquier recurso propiedad de Cuatroochenta debe emplearse exclusivamente para fines laborales.

Cuatroochenta establece el uso aceptable de los equipos de la compañía en base al **modelo COBO (*Corporate Owned, Business Only*)**. Este modelo presenta un escenario donde el control por parte de la empresa es total y sólo está permitido el uso corporativo.

Mediante el presente documento, Cuatroochenta regula el uso de los recursos tecnológicos estableciendo medidas de cumplimiento obligatorio para todo el personal, los cuales quedan sujetos a esta normativa, así como a los principios morales y éticos en la utilización de los recursos puestos a disposición del usuario para el desempeño de sus funciones laborales.

El uso inapropiado, abusivo, o que escape a los hábitos tolerados de los servicios de comunicación y de los medios tecnológicos, será sancionado con la eliminación del acceso a los recursos, la aplicación de las sanciones disciplinarias derivadas por incumplimiento de los términos y condiciones que emanen de la relación laboral, además de las sanciones legales establecidas en la normativa vigente aplicable.

La compañía podrá realizar las investigaciones y controles que resulten necesarios tanto de los equipos como de las herramientas facilitadas al usuario por parte de la empresa, lo que incluye entre otros el correo electrónico empresarial o cualquier dispositivo, dentro del ámbito de potestades de control del empresario del Art.20.3 del Estatuto de los Trabajadores.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

El control de estos medios se llevará a cabo sin dañar y sin atentar contra la dignidad o intimidad del usuario, dada cuenta del conocimiento que tiene éste del objeto y la existencia del presente control y fiscalización a la que los usuarios son sometidos.

Las finalidades genéricas de este control son las siguientes:

- Protección del sistema y red informática y de los equipos que lo conforman, a fin de proteger la integridad del Sistema y la Seguridad de la Información.
- Cumplimiento de políticas de seguridad.
- Garantizar la continuidad del trabajo en el caso de que el usuario se ausente por razón de enfermedad, vacaciones u otras similares.
- Prevención de la responsabilidad frente a terceros.
- Comprobación del cumplimiento de las obligaciones laborales del usuario.
- Comprobación de la existencia o no del uso abusivo de los medios tecnológicos facilitados por la empresa para usos personales durante el horario laboral.
- Investigación de incidentes.

Por tanto, todos los contenidos, informaciones y ficheros almacenados en el mismo, incluida la información de carácter temporal, podrán ser accedidos por parte de la empresa o de los responsables designados al efecto, habida cuenta de que el usuario, plenamente informado, se abstendrá de introducir información íntima en el sistema de información de Cuatroochenta.

Este apartado recoge una serie de normas o recomendaciones que se han definido para proteger a los empleados de la compañía y sus recursos. Las tecnologías críticas cuyo uso está regulado en esta política incluyen:

- Dispositivos de red
- Sistemas Operativos
- Aplicaciones
- Tecnologías de acceso remoto
- Tecnología WiFi
- Ordenadores Personales (PCs y Laptops) y servidores
- Smartphones
- Uso de internet
- Uso de correo electrónico
- Uso de otras plataformas corporativas

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

Para ello, se han diseñado una serie de políticas que deben ser llevadas a cabo a la hora de acceder a la información de Cuatroochenta y que podemos dividir según la siguiente clasificación:

5.1 5.1.- DE DISPOSITIVOS

Cualquier dispositivo que pertenezca a la compañía y que sea utilizado para acceder a sus recursos, está sujeto a las normas y procedimientos de instalación siguientes:

1. Todo equipo o soporte móvil que vaya a ser usado fuera de las instalaciones de Cuatroochenta debe estar cifrado.

2. La configuración del sistema operativo y del resto de componentes debe ajustarse a la *"línea base"* definida por el Comité de Sistemas (en base a los *benchmarks* del CIS[5]) bajo supervisión del Comité de Seguridad Interna, teniendo en cuenta aquellos requerimientos de seguridad específicos que pudieran aplicar. Queda terminantemente prohibido alterar por parte del usuario dicha configuración.

3. Los diferentes componentes software instalados deben mantenerse siempre actualizados, según recomendación y disponibilidad de fuentes oficiales.

4. Para el control de acceso, cada usuario tiene habilitado en su equipo un usuario con credenciales exclusivas. En cada equipo existe un usuario extra "administrador" cuya contraseña será custodiada en un gestor de contraseñas, y se empleará únicamente con fines de administración.

5. En caso de que el dispositivo sea utilizado por varios usuarios, se creará y utilizará otro usuario no administrador o espacio de trabajo (*workspace*). Separando los perfiles y no permitiendo el acceso a información cruzada entre ellos.

6. Cualquier equipo que se utilice para acceder a información de la compañía debe poseer software de seguridad instalado, activo y actualizado: EDR MS Defender[6] o CrowdStrike[7], software que permita la administración del dispositivo y sus aplicaciones (Microsoft Intune[8] en *end-point* y Azure Arc[9] en servidores) y protección del acceso a la web y la nube mediante Netskope[10] en los *end-point*.

7. Respecto a la descarga y/o instalación de aplicaciones en los dispositivos cuyo uso esté asignado a un usuario, la norma genérica será la prohibición salvo que sea necesaria para el trabajo que deba desempeñar dicho usuario.

8. Del mismo modo, queda terminantemente prohibida la activación, descarga y/o instalación de software que permita el acceso remoto al equipo. En el supuesto de que cualquier usuario precise de dicho servicio solicitará autorización expresa al Comité de Seguridad Interna a través del gestor de tareas.

9. Respecto a la información contenida en los dispositivos y su copia de seguridad, se define:

    a. La información almacenada en los equipos debe ser la mínima necesaria para desarrollar las labores actuales.

    b. En caso de no ser posible trabajar directamente sobre la plataforma destino, una vez finalizado el trabajo, se ubicarán los archivos en los repositorios corporativos correspondientes (Sharepoint, BitBucket…) y se eliminarán del equipo.

    c. Se mantendrá una copia de seguridad de los archivos laborales "personales" o en proceso en el espacio asignado en la plataforma OneDrive vinculada al perfil profesional de Cuatroochenta.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

10. Los usuarios de los equipos de uso exclusivo deberán responsabilizarse tanto de los dispositivos asignados como de cumplir con las políticas de seguridad establecidas por Cuatroochenta en los mismos.

11. Los responsables de las distintas áreas deberán coordinarse con el equipo de sistemas para registrar y actualizar el inventario tanto del personal como de los equipos de uso exclusivo del mismo.

12. El usuario evitará el uso de su equipo por terceras personas.

13. Cualquier equipo nuevo debe ser configurado de forma acorde a esta política por parte del equipo de sistemas del área al que se destina, quedando la petición registrada a través del gestor de tareas.

14. Cualquier dispositivo o servicio que sea de propósito específico y tenga una misión crítica asignada, requiere estar ubicado en el CPD (Centro de Proceso de Datos) o infraestructura cloud habilitada a tal efecto, las condiciones ambientales, la alimentación eléctrica y su acceso está regulado mediante los mecanismos oportunos.

15. El acceso a la información de la compañía desde ordenadores portátiles y otros dispositivos ajenos a Cuatroochenta, se hará siempre garantizando la seguridad. Para ello, el usuario se compromete a no mantener ninguna copia en local de la información y a cumplir con las normas establecidas en este documento.

16. Una vez alcanzado el fin de la vida útil de los dispositivos o componentes de almacenamiento, éstos deberán ser debidamente tratados para garantizar la eliminación de los datos bien por procedimientos software o bien por la destrucción física del dispositivo.

En el caso de no haber proporcionado al empleado dispositivos corporativos y vayan a utilizarse los personales, se recomienda que, en la medida de lo posible, se sigan las mismas medidas especificadas anteriormente. En el caso de no cumplir alguna de las medidas consideradas como básicas, se podrá restringir el acceso a algunas plataformas o recursos desde ese dispositivo.

5.2 DEL CONTROL DE ACCESOS

5.2.1 Acceso físico

A nivel general, el acceso a las instalaciones de Cuatroochenta debe ser restringido y controlado, para ello cada empleado dispondrá de medios físicos específicos según las características y posibilidades de la oficina (llave, tarjeta de identificación, control biométrico…).

Las puertas de estas instalaciones deberán permanecer cerradas y, cualquier visita ajena a la compañía, deberá identificarse, validarse y vigilar su estancia en las instalaciones.

El acceso a áreas críticas como el SOC o los espacios donde se ubican los armarios de comunicaciones y electrónica de red, queda totalmente restringido a aquellos usuarios que deban ejercer su labor en estas áreas, aplicando el principio de mínimos privilegios. En caso de que personal externo, de forma justificada, deba realizar alguna acción en ellas, se realizará siempre acompañado de un empleado de la compañía y extremando las medidas de seguridad.

Además, el acceso físico a la información que pueda desprenderse del puesto de trabajo debe protegerse mediante la *Política de Mesas Limpias* establecida en la sección 4 del presente documento.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

5.2.2 Acceso lógico

A nivel general, el acceso a cualquier dispositivo o plataforma que pueda contener información sensible debe estar restringido y controlado, para ello cada empleado dispondrá de credenciales específicas según las características técnicas del mismo.

Las credenciales son un aspecto fundamental de la seguridad de la información. Unas credenciales mal establecidas o protegidas pueden suponer un problema de seguridad en toda la organización.

Para que el acceso lógico a los recursos de Cuatroochenta sea responsable y seguro, se establecen las siguientes normas y procedimientos:

1. Todos los empleados que necesitan acceso a algún dispositivo o plataforma dispondrán de las credenciales oportunas y serán responsables de las mismas.

2. Las contraseñas asignadas en el momento del alta por el administrador o responsable deberán ser cambiadas por el empleado en el primer acceso o lo antes posible.

3. Los permisos asociados al usuario de cada empleado serán conformes a sus funciones, responsabilidades y actividades, siguiendo el principio de mínimos privilegios. Estos permisos deberán ser revisados de forma periódica.

4. Todos los usuarios son responsables de proteger sus credenciales. Para ello, deberán utilizar el gestor de contraseñas corporativo (Zoho Vault[11]), y no revelar las contraseñas personales a nadie.

5. Nunca escribiremos en texto plano ni transmitiremos abiertamente nuestras contraseñas a través de ningún medio físico (post-it, papel, conversación, etc.) o lógico (documento, correo, chat, llamada, plataforma, etc.).

6. Siempre que sea posible, las credenciales deben ser específicas para cada usuario.

7. Cuando la tecnología lo permita, el usuario, por defecto, contará con permisos básicos y deberá realizar, de forma temporal, un “escalado de privilegios” para acceder a las funciones administrativas. Quedando, además, traza de este escalado y de las acciones realizadas.

8. En caso de ser necesario compartir internamente algunas credenciales, se hará exclusivamente a través del gestor de contraseñas corporativo.

9. Cuando la tecnología lo permita, se activará el bloqueo de sesión tras un periodo de inactividad razonable (10 minutos).

10. Cuando la tecnología lo permita, se bloqueará la cuenta del usuario tras tres intentos fallidos de acceso. El desbloqueo de la cuenta deberá ser realizado por un usuario administrador autorizado de la plataforma dónde se ha producido.

11. Salvo prueba de lo contrario, se presumirá que los actos que se lleven a cabo con las credenciales asignadas a un empleado han sido realizados por el mismo.

12. Si un usuario sospecha que sus credenciales están siendo utilizadas ilegalmente, es su responsabilidad notificarlo inmediatamente al CISO.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

5.2.3 Credenciales y contraseñas

Aunque en la mayoría de las ocasiones el tipo de credenciales será determinado por las capacidades técnicas de los dispositivos o plataformas, se establecen tres niveles de credenciales que serán aplicadas en el siguiente orden de prioridad:

1. En aquellos dispositivos y plataformas que lo permitan, se forzará el inicio de sesión único (Single Sign-On – SSO) implementado a través de las credenciales de MS365.

2. En aquellos dispositivos y plataformas que lo permitan, además de una contraseña robusta, se forzará un segundo factor de autenticación (MFA) como Google Authenticator o Microsoft Authenticator (de uso preferente).

3. Credenciales basadas en una contraseña robusta.

Por otra parte, a nivel general, en base a criterios de seguridad y el poder de cómputo actual, se establece la siguiente ***Política de Contraseñas***:

1. Queda terminantemente prohibido el uso de contraseñas por defecto y, en la medida de lo posible, se evitarán usuarios genéricos.

2. No se reutilizarán las mismas contraseñas en diferentes servicios o dispositivos.

3. Las contraseñas escogidas por los usuarios deben ser difíciles de adivinar y no deben contener información relacionada con su trabajo, usuario y/o su vida personal.

4. Siempre que no esté técnicamente limitado, se establece una longitud mínima de la contraseña de 12 caracteres.

5. La contraseña debe contener, al menos, una mayúscula, una minúscula, un número y un símbolo.

6. Las contraseñas deben ser cambiadas, al menos, anualmente.

7. Cuando la tecnología lo permita, el sistema controlará que no se reutilicen las últimas tres contraseñas.

Para facilitar el cumplimiento de los puntos anteriores y proteger de forma adecuada las credenciales, se establece el uso obligatorio del gestor de contraseñas corporativo (Zoho Vault). Este gestor permite almacenar de forma segura tanto las credenciales corporativas como las personales, generar contraseñas que cumplan con los requerimientos establecidos, compartirlas en caso necesario y controlar su uso.

Si en alguna ocasión debemos compartir credenciales con personal externo a Cuatroochenta y no es viable hacerlo a través del gestor de contraseñas, se realizará dividiendo la contraseña en dos partes que serán transmitidas por dos canales de comunicación con el receptor verificados y habituales (teléfono, SMS, chat, correo…).

5.3 DEL CORREO Y OTRAS PLATAFORMAS.

Cuatroochenta proporcionará a cada empleado una cuenta corporativa de MS365, que deberá emplearse para cualquier comunicación interna o externa en el entorno laboral, tanto a través del correo electrónico como a través de chat o videoconferencia. Adicionalmente, la compañía proporcionará a cada usuario las cuentas necesarias de aquellas plataformas que se requieran para el correcto desempeño de sus labores.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

Es obligación de cada empleado hacer un uso responsable de todas estas plataformas, y no emplear recursos productivos facilitados por Cuatroochenta para usos no pertinentes. Debido a que las cuentas corporativas son cedidas por Cuatroochenta para uso profesional del empleado, el usuario deberá atenerse a las reglas establecidas por la compañía para su uso.

Tanto el uso del correo electrónico para comunicaciones corporativas como el uso de cuentas en otras plataformas con fines laborales estará limitado a las cuentas de la organización, no pudiendo utilizar cuentas personales, y deberá cumplir con el propósito del desempeño del trabajador.

La transmisión de información sensible a través del correo electrónico u otras plataformas deberá estar justificada y autorizada para la finalidad exclusiva para la cual se produce. Siendo necesaria la inclusión en los mensajes salientes de la cláusula relativa a la confidencialidad de los datos y la utilización del contacto exclusivamente para el fin de dicha comunicación.

Las plataformas de comunicaciones y, especialmente el correo electrónico, son foco de múltiples ataques y la principal puerta de entrada de *malware*. Si bien se dispondrán de medidas técnicas por parte de Cuatroochenta para evitar el spam, el phishing, las cuentas no autorizadas, etc… será responsabilidad del usuario el buen uso de estos medios y de extremar las precauciones al abrir e interpretar cualquier mensaje. Para ello, se aconseja seguir las siguientes recomendaciones:

- No confiar únicamente en el nombre del remitente y verificar minuciosamente su dirección de envío, así como también cualquier enlace web o correo al que te dirija el mensaje.
- Sospechar de mensajes con faltas de ortografía o errores gramaticales, los que requieren una urgencia injustificada o los que no proporcionan información completa como debería.
- No abrir ningún enlace ni descargar ningún archivo procedente de un correo que presente cualquier síntoma o patrón fuera de lo normal o habitual.
- Verificar siempre la extensión de los ficheros y no habilitar las macros de los documentos ofimáticos.
- Tener cuidado con las solicitudes de credenciales o datos personales a través de plataformas a las que se ha llegado siguiendo un enlace contenido en un mensaje o correo electrónico. Confiar únicamente en fuentes oficiales y acceder directamente a sus plataformas.

En caso de correos especialmente críticos o por requerimiento de terceros, podremos cifrar los mensajes para asegurarnos de que sólo los destinatarios pueden leerlo y de su integridad. Para ello, recurriremos a PGP mediante el uso de Mailvelope[12] sobre la misma plataforma.

5.4 DE HERRAMIENTAS DE INTELIGENCIA ARTIFICIAL (IA)

El uso de herramientas basadas en inteligencia artificial (IA), tales como asistentes conversacionales, generadores de texto o análisis automatizados, está cada vez más extendido en el entorno profesional. No obstante, su utilización debe estar sujeta a estrictas medidas de seguridad y protección de la información.

Está prohibido introducir en herramientas de IA información corporativa sensible (clasificada como *RESTRINGIDO* (**TLP:AMBER**) o *CONFIDENCIAL* (**TLP:RED**)), o sujeta a secreto profesional, así como datos personales de clientes, empleados o terceros.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

Aunque muchas de estas plataformas afirman no almacenar información introducida por los usuarios, en la práctica pueden emplear dichos datos para el entrenamiento de sus modelos. Esta práctica representa un riesgo potencial para la privacidad de los datos personales y para la seguridad de la información corporativa.

El uso de esta tecnología se regula con mayor detalle en el *Playbook de Políticas y Buenas Prácticas en el Uso de IA en Cuatroochenta*. De forma resumida, y en línea con la política de seguridad de la entidad, se deberán seguir estas directrices:

- No utilizar herramientas de IA externas para tratar o consultar información sensible o confidencial de Cuatroochenta.
- No introducir nombres, direcciones, DNI, números de cuenta, correos electrónicos, teléfonos ni ningún otro dato identificativo de personas físicas o jurídicas.
- En caso de requerirse el uso de IA con fines profesionales, deberá utilizarse exclusivamente tecnología autorizada por el área de seguridad y con garantías de cumplimiento normativo (LOPDGDD, RGPD, etc.).

Cualquier duda sobre el uso permitido de estas herramientas deberá ser consultada con el Comité de Seguridad Interna, liderado por el CISO.

5.5 DE CONECTIVIDAD

5.5.1 Red corporativa

En cada una de sus oficinas Cuatroochenta cuenta con una red corporativa que brinda a sus usuarios la posibilidad de acceder a diferentes recursos a través de Internet. Nos referiremos en este apartado a las concretas medidas que habrá que adoptar para intentar garantizar la seguridad tanto de los recursos corporativos como de todos aquellos usuarios que accedan a la red (ya sea por cable o vía WiFi).

A nivel técnico, según las características y necesidades de cada oficina, las redes deben estar correctamente segmentadas y disponer de un *Firewall* que analice y filtre las conexiones entrantes y salientes, restringiendo el uso de los puertos de red a los estrictamente necesarios. Adicionalmente, para el acceso inalámbrico, se habilitará la conexión configurando un protocolo de seguridad WPA2 con un cifrado AES y una contraseña robusta.

En el caso de necesitar dar acceso a Internet a personal ajeno a Cuatroochenta, se hará a través de una red específica para invitados separada y sin visibilidad al resto de la red corporativa.

Actualmente Internet es una herramienta indispensable para el acceso a todo tipo de información y servicios. Pero, a la vez, también es la puerta de entrada a peligros derivados del uso inadecuado de esta tecnología. Por ello, deberán adoptarse las siguientes medidas para minimizar este riesgo:

1. Siempre que sea posible, el acceso a información corporativa se realizará a través de la red de datos corporativa.
2. En el trabajo, Internet tiene carácter laboral y no debe usarse con otros fines. Los usuarios son responsables de las sesiones iniciadas desde sus terminales y de la actividad que se lleve a cabo a través de estas.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

3. Se prohíbe expresamente el acceso, descarga y/o almacenamiento en cualquier soporte, de páginas o contenidos ilegales o inadecuados.

4. Se monitoriza de forma continua y con varias herramientas el uso de la red para comprobar que no se hace un uso indebido de los recursos de Cuatroochenta por los cuales se pueda producir un fallo de seguridad.

5. No está permitido conectar a la red corporativa dispositivos que no cumplan las medidas establecidas en la presente política de seguridad ni aquellos que no sean de uso laboral.

6. No está permitido conectar a la red corporativa dispositivos que no cumplan las medidas establecidas en la presente política de seguridad ni aquellos que no sean de uso laboral.

7. El usuario deberá utilizar su propio servicio de conexión y acceso a Internet, así como sus propias cuentas personales para las necesidades privadas de comunicación y acceso a servicios privados que precise dentro de su horario laboral.

En caso de ser necesario comunicar las redes corporativas entre diferentes oficinas, se realizará siempre habilitando túneles debidamente cifrados entre las mismas (IPSec).

5.5.2 Acceso remoto y teletrabajo

Exceptuando la administración de sistemas, y algunos casos concretos, los empleados no necesitan acceder a la red corporativa de Cuatroochenta desde fuera de la misma, pues todas las tareas se realizarán contra las plataformas *cloud* habilitadas por la empresa, bien de forma pública o a través de ZTNA.

De forma general, el usuario que realice sus labores en modo teletrabajo fuera de las instalaciones de Cuatroochenta se compromete a adoptar las medidas de seguridad físicas y de conectividad para garantizar que el acceso a la información sensible se realiza de manera responsable y con la misma política de seguridad de la organización. Para ello, se podrán utilizar los dispositivos móviles (portátiles, smartphones) proporcionados por la empresa o, en su defecto, equipos no corporativos, siempre y cuando se garantice el cumplimiento de las medidas de seguridad establecidas en este documento.

En caso de pérdida o robo de un dispositivo corporativo se deberá contactar de forma inmediata con el CISO.

En la medida de lo posible, se evitará el teletrabajo realizado desde instalaciones o recursos compartidos o públicos. Especialmente en lo que a conectividad se refiere, se primará siempre el uso de conexiones propias y confiables (red doméstica o telefonía móvil) sobre cualquier otra opción compartida.

En el modelo de teletrabajo extendido en Cuatroochenta, dónde se desdibujan los límites habituales de una red corporativa tradicional, se ha apostado por tener una capa adicional de seguridad mediante Netskope que proporciona:

- Protección contra sitios web maliciosos: Se bloquean aquellos sitios identificados como maliciosos, p.e. aquellos sitios a los que se redirigen en un ataque de phishing.

- Análisis de malware: Como complemento al EDR, se revisan los archivos que se descargan o suben en busca de malware.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

- Prevención de fuga de datos sensibles (DLP): En sitios no corporativos, se emite un aviso cuando se esté exponiendo información potencialmente sensible.

- Acceso transparente a recursos internos (ZTNA): Los usuarios, sin estar pendientes de conectarse a diferentes VPNs, tendrán acceso directo a los recursos internos que necesiten.

- Protección en redes no confiables: En caso de necesitar acceder a una WiFi pública, con Netskope se elimina la necesidad de realizar la conexión a través de una VPN, se dispone de protección de forma transparente.

Como alternativa a Netskope, cuando no se pueda acceder a una conexión confiable desde el smartphone, se dispone también de la conexión segura mediante VPN (UareSAFE), a través de la que se podrá acceder con garantías al resto de recursos.

Por otra parte, el acceso remoto a los servidores y a la administración de infraestructuras *cloud* únicamente será posible desde dentro de la intranet de Cuatroochenta y por parte del personal que este designe a tal efecto. Para ello, se restringirán las IPs de acceso, habilitando únicamente las correspondientes a la oficina.

Cuando sea necesario acceder a la red corporativa de forma remota, se habilitará un usuario nominal y con registro de auditoría en la VPN corporativa gestionada a través del *firewall* Cisco Meraki.

En este tipo de conexiones, el usuario dispondrá de los mismos permisos y accesos que desde su puesto de trabajo local. Además, se establece la desconexión automática de sesiones después de un período de una hora de inactividad.

Finalmente, en caso de ser necesario el acceso remoto por parte de terceros (clientes, proveedores), se les proporcionaran las credenciales oportunas con una fecha de caducidad que obligue a la desactivación inmediata después del uso requerido y se asegurará que sólo puedan acceder a los recursos necesarios.

5.6 DE PROTECCIÓN DE LA PROPIEDAD INTELECTUAL

Está estrictamente prohibida la instalación y/o utilización de programas informáticos en los Sistemas de Información de Cuatroochenta sin la correspondiente licencia de uso. Este comportamiento estará sometido a las previsiones disciplinarias, administrativas, civiles o penales descritas en las leyes.

Como se establece al inicio de la relación laboral, Cuatroochenta se reserva los respectivos derechos de propiedad industrial e intelectual sobre invenciones, mejoras, marcas, secretos industriales, ideas, Derechos de Autor, desarrollados por los empleados o en los que hayan participado, con motivo de sus actividades o empleo, tal y como se regula en el art.51 del Real Decreto legislativo 1/1996, de 12 de abril, por el que se aprueba el texto refundido de la Ley de Propiedad Intelectual, así como el Título IV de la Ley 24/2015, de 24 de Julio, de Patentes.

5.7 DE CONTROLES CRIPTOGRÁFICOS

Se establece el uso de cifrado en las siguientes situaciones:

- Para proteger la información sensible y/o aquella transportada en dispositivos móviles o en medios extraíbles.

- Para asegurar el acceso remoto a los sistemas a través de las líneas públicas de comunicación.

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

Para los casos establecidos, los algoritmos y longitudes de clave que a continuación se mencionan son los que a la fecha se consideran seguros. Se seguirá lo dispuesto en la guía CCN-STIC 807 Criptología de empleo en el Esquema Nacional de Seguridad.

Algoritmo	Longitud de Clave
AES[13]	>= 112 bits
RSA	2048 bits
SHA-2	SHA-2 256bits o superior
SHA-3	SHA-3 256bits o superior

5.8 DE FIRMA ELECTRÓNICA

Cuando se requiera la firma de algún documento (contrato, oferta, autorización, etc.), podrá sustituirse la firma manuscrita por una firma electrónica válida y de acuerdo con la legislación vigente, perteneciente al usuario autorizado a la firma de dicho documento.

En el caso, de firmas a nivel personal, se utilizarán certificados de personas físicas, y cuando se trate de firmas como representantes de la organización con certificados de persona física representante de persona jurídica (apoderados), según se establece en la *Política de uso del Certificado Digital* de nuestro sistema de *Compliance*.

Se podrá utilizar cualquier medio de firma electrónica de los reconocidos por la legislación vigente. En este sentido, los protocolos de firma electrónica harán uso de certificados digitales con:

a. claves RSA (del firmante) de, al menos, 2048 bits, o

b. claves de 224-255 bits si se emplean curvas elípticas.

No se admitirá el uso de certificados cuya función resumen (en inglés, *hash*) sea la función MD5, SHA-1 o RIPEMD-160 u otra de seguridad inferior.

En caso de dudas si el certificado es adecuado, consultar con el CISO.

5.9 DE SUPERVISIÓN Y EVALUACIÓN

Con el fin de monitorizar la disponibilidad de los recursos, garantizar el mantenimiento de las medidas implementadas y vigilar cualquier amenaza que pueda acechar, se establecen las normas y procedimientos de supervisión y auditoria siguientes:

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

1. Los servidores considerados críticos se encuentran bajo monitorización permanente vía sensores específicos sobre los recursos y capacidades críticas de los mismos.

2. Periódicamente y con herramientas de diagnóstico automatizadas se comprobará que la configuración de los servidores cumple con la línea base de seguridad establecida para los mismos.

3. Periódicamente se realizará un escaneo interno y externo de la red corporativa de Cuatroochenta en busca de posibles fallos y vulnerabilidades.

4. Se realizarán de forma regular y automatizada las copias de seguridad y pruebas de recuperación de ficheros según lo establecido en los procedimientos correspondientes basados en la regla 3-2-1.

5. De una forma continuada y proactiva, el software de seguridad revisará los equipos de la organización para detectar y bloquear cualquier posible amenaza o comportamiento anómalo que haya podido pasar por otros controles de seguridad previos.

6. En las oficinas de Cuatroochenta, e interconectado con las diferentes plataformas cloud que lo permitan, se dispondrá de una sonda de Darktrace[14] que estará analizando todo el tráfico de red en busca de anomalías que puedan suponer un riesgo para la organización.

7. Tanto a través de Netskope como de los firewalls Cisco Meraki y servidores DNS seguros[15], se bloqueará el acceso a aquellos sitios que sean considerados maliciosos, así como también aquellos no apropiados para un entorno laboral según el criterio del departamento de RRHH.

8. Con el fin de determinar y monitorizar la superficie de exposición con relación a vulnerabilidades y deficiencias de configuración, se ha implementado un ASM (*Attack Surface Mangement*) básico utilizando Shodan[16].

9. Como se desprende del presente documento, toda la información de Cuatroochenta debe residir exclusivamente en las plataformas corporativas habilitadas y/o en los dispositivos corporativos. Por ello, a través de Netskope se monitorizará el acceso a instancias personales de estas plataformas o cuentas no corporativas en plataformas de almacenamiento en cloud.

10. La mayoría de las plataformas utilizadas por Cuatroochenta permiten llevar un control de incidencias mediante alertas que serán monitorizadas en el SOC, y permiten extraer informes periódicos sobre determinados comportamientos de riesgo para la supervisión por parte del equipo de seguridad.

11. En función de las incidencias de seguridad detectadas y las vulnerabilidades identificadas en los informes y boletines de seguridad recibidos por organismos oficiales como INCIBE o el CCN, el Comité de Seguridad Interna adoptará las medidas de índole técnica y organizativa necesarias para evitar su materialización en caso de que puedan afectar al software y hardware en explotación. También se informará a los usuarios mediante los canales de difusión interna habituales.

12. En caso de incidente o sospecha, Cuatroochenta se reserva el derecho de monitorizar e inspeccionar el correcto uso de sus recursos por parte de los empleados en cualquier momento, respetando la legislación vigente en cuanto al derecho de privacidad de estos. Estas comprobaciones pueden llevarse a cabo con o sin el consentimiento y presencia del empleado involucrado, y contarán con el consentimiento expreso de la Comisión Ejecutiva de Cuatroochenta.

Los usuarios tendrán la obligación de permitir y facilitar en base a sus posibilidades la realización de estos controles y revisiones internas periódicas.

6. SANCIONES

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

Cualquier violación de estas políticas y normas de seguridad será sancionada según el criterio de la Comisión Ejecutiva de Cuatroochenta y siempre de forma acorde a los mecanismos habilitados por la legislación vigente.

Todas las acciones en las que se comprometa la seguridad de Cuatroochenta y que no estén previstas en esta normativa, deberán ser revisadas por el Comité de Seguridad Interna y, en caso de ser necesarias acciones disciplinarias, éstas serán establecidas por la Comisión Ejecutiva en base al criterio de la organización y la legislación prevista.

En este sentido, todo empleado de Cuatroochenta debe entender que asume una obligación laboral específica y que, en caso de incumplimiento, podría ser motivo de despido por causa justa. Adicionalmente, Cuatroochenta se reserva el derecho de emprender las acciones judiciales pertinentes por cualquier daño o perjuicio que pudiera derivarse para él mismo y/o terceras personas.

7. MANTENIMIENTO Y REVISIÓN DE NORMATIVA

El Comité de Seguridad Interna liderado por el CISO es el responsable establecer, documentar, mantener y distribuir las Políticas de Seguridad, estándares, directivas y procedimientos de seguridad de Cuatroochenta.

La Dirección de Cuatroochenta es responsable de la revisión y aprobación de esta Normativa. Cualquier cambio o evolución que afecte o pudiera afectar al contenido del documento de Normativa de Seguridad quedará registrado en una nueva firma del documento de aprobación. De esta forma se concreta y confirma el compromiso de la dirección general por la seguridad de la información.

La Normativa de Seguridad es un documento *"vivo"*, por lo que deberá seguir un proceso de actualización constante sujeta a hechos relevantes: incidencias encontradas en el sistema, cambios en la infraestructura, desarrollo de nuevos servicios, entre otros. Periódicamente, y en todo caso no superando el plazo de un año, se revisará la vigencia y razonabilidad de la presente política y se llevarán a cabo las mejoras, adaptaciones o modificaciones requeridas en función de los cambios organizativos, técnicos o regulatorios aplicables. De esta evolución se desprenderá un listado de acciones a emprender y ejecutar durante el año siguiente para garantizar la seguridad y el buen uso de los recursos de Cuatroochenta.

8. DISTRIBUCIÓN DE LA NORMATIVA

La Normativa de Seguridad será accesible para todas las partes interesadas.

Cualquier cambio sustancial en el documento será distribuido a todos los usuarios a través de una notificación formal, enviada por correo electrónico o por comunicación interna en medios accesibles a los mismos.

9. APROBACIÓN

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI

La presente *Normativa de Seguridad* ha sido aprobada por la Dirección de Cuatroochenta, con vigencia a partir de la fecha de su firma y hasta que sea reemplazada por una nueva Normativa.

Representante: Sergio Aguado González

Fecha: 29/08/2025

Firma:

Firmado digitalmente por

Nombre : Jordi Melchor
Hora : mar 23 2026 12:41 CET
Firmado con : Zoho Sign
BD14155EDA52985E1ECC1DB7716B89E6BAB...

Zoho Sign Document ID: 4ABE13AD5-I-UILWUTYHAKZ9SX2_LBOSPWKODR82YEX8XFSWVO0MI